LEARNER ATTACHMENT

HIPAA SOPs and Pre-Approved Runbooks

Contoso Health training simulation | Controlled baseline | Version 1.0 | Effective 09/04/2026

TRAINING CONTROL These identifiers create a complete, auditable simulation. A healthcare organization must replace them with its approved production policies, named officials, channels, and response authority before operational use.

Runbook IR-01 - Suspected credential compromise

Criterion	Trigger	Required routing
IR-01.A	Suspicious message or link with no credential entry and no identity-risk signal	Preserve/report message; SOC triage
IR-01.B	Credentials entered, unexpected MFA interaction, risky sign-in, or suspected session misuse	Immediate SOC transfer; IAM containment/remediation under authorized role
IR-01.C	Possible ePHI repository or clinical file involvement	Apply PRIV-01 in parallel

Runbook EVID-01 - Evidence preservation

- Preserve message, incident/alert IDs, Entra sign-in/risk records, relevant Purview audit events, user statement, and exact time window.
- Store originals unchanged in the restricted evidence repository. Use evidence IDs in handoffs.
- Do not export, forward, or alter evidence unless the approved collection procedure authorizes it.

Runbook PRIV-01 - Possible ePHI access, use, or disclosure

Criterion	Trigger	Required routing
PRIV-01.A	Possible ePHI involvement plus suspected credential/session misuse or unauthorized file-access signal	HIPAA Privacy & Compliance Office review; cite IR-01 and file/audit evidence
PRIV-01.B	Over-broad sharing, guest access, anonymous link, or permissions drift affecting PHI	Information Governance and HIPAA Privacy & Compliance Office
PRIV-01.C	No ePHI or individually identifiable health information involved, supported by evidence	Document basis; privacy transfer not triggered unless another criterion applies

Runbook PRIV-02 - Breach determination

- Only the designated privacy function determines whether an impermissible use or disclosure occurred.
- The privacy function applies the HIPAA Breach Notification Rule, including exceptions and the four-factor risk assessment when applicable.
- Tier 1, SOC, IAM, and Information Governance provide facts and mitigation evidence but do not declare breach or notification status.

Runbook M365-01 - Shared-file governance finding

- Preserve current permissions, sharing link details, guest membership, and related audit events before approved remediation.
- Information Governance owns link and permissions review; SOC owns threat investigation; Privacy Office owns privacy implications.

Mock-ticket routing decision

TKT-00517 meets IR-01.B because credentials were entered and a risky sign-in is present. It also meets IR-01.C and PRIV-01.A because the affected identity is associated with a PHI-bearing SharePoint file and an anomalous file-access event. Required transfers: SOC, IAM for the Conditional Access exception, Information Governance for the Anyone link, and HIPAA Privacy & Compliance Office. Tier 1 does not determine breach status.

Authoritative sources

- HHS - Summary of the HIPAA Security Rule
- HHS - Breach Notification Rule
- Microsoft - Compromised identity incident response SOP template
- Microsoft - Phishing investigation playbook
- Microsoft Entra - Investigate identity risk
- Microsoft Purview - Use sharing auditing in the audit log